

Nexus Inventory

Estrategia de seguridad y control de acceso

1. Contexto

La seguridad de la aplicación es fundamental para proteger los datos de usuarios y garantizar que cada usuario solo pueda acceder a las funciones que le corresponden.

El sistema contará con **autenticación mediante tokens JWT** y **control de acceso por roles** para asegurar la segregación de permisos entre administradores y cajeros.

2. Estrategia de autenticación

- Se utilizará **JWT (JSON Web Token)** para autenticar a los usuarios.
- El flujo básico será:
 1. El usuario ingresa su **usuario y contraseña** en el formulario de login.
 2. El backend valida las credenciales.
 3. Si son correctas, el backend genera un **token JWT**.
 4. El cliente almacena temporalmente el token y lo envía en cada petición al backend.
 5. El backend verifica el token antes de responder a cada petición.
- El sistema permitirá **logout**, eliminando el token del cliente y evitando accesos posteriores.

3. Roles y permisos

Se definen **dos roles principales**:

Rol	Permisos Principales
Admin	Acceso completo: gestión de usuarios, productos, categorías, inventario, facturas y reportes

Cajero	Acceso limitado: registrar ventas, generar facturas, ver stock de productos, sin acceso a gestión de usuarios o categorías
--------	--

- Cada endpoint o funcionalidad estará **protegido según el rol del usuario**.
- Solo los usuarios con permisos suficientes podrán ejecutar ciertas acciones.

4. Protección de rutas y endpoints

- Todas las rutas del backend estarán **protegidas mediante JWT**.
- El backend verificará el token en cada petición y comprobará el rol del usuario.
- Los endpoints que solo deben usar administradores estarán **bloqueados para cajeros**.
- Las rutas públicas serán únicamente aquellas necesarias para el login.

5. Posibles riesgos y mitigaciones

Riesgo	Mitigación
Robo de credenciales	Contraseñas almacenadas en hash seguro, uso de HTTPS para proteger la transmisión de datos
Uso de token robado	Tokens tienen fecha de expiración y se verifica cada petición
Acceso a funcionalidades restringidas	Control de acceso basado en roles en todos los endpoints
Inyección de datos	Validación de inputs en formularios y endpoints del backend